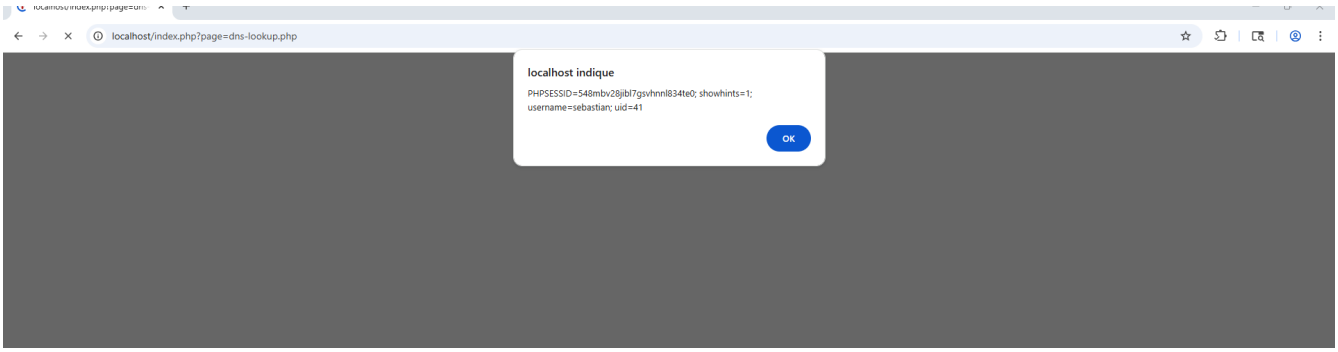
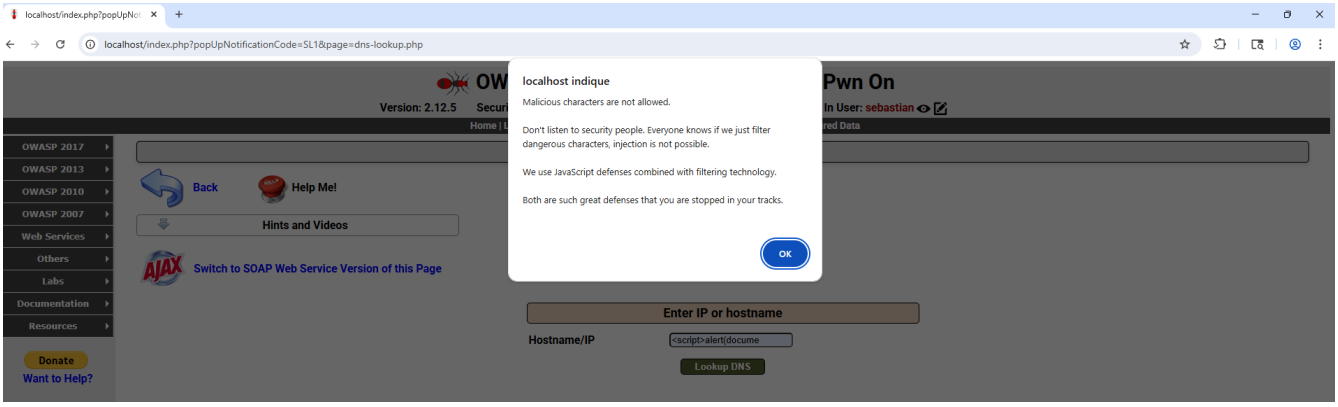
Défi N°1

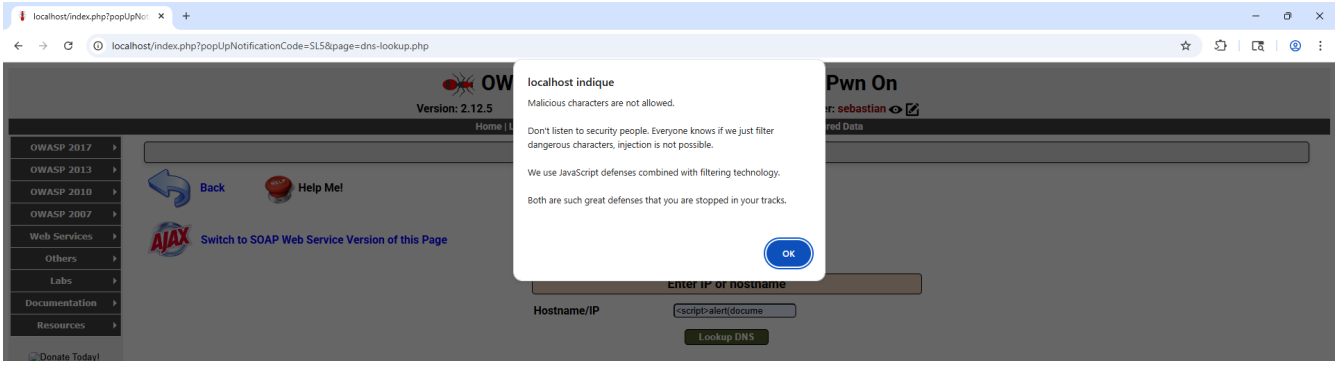
niveau 0:



niveau 1:



niveau 5:



QUESTIONS:

(Q1) ce que le niveau de sécurité 1 permet d'éviter l'attaque avec Burpsuite ?

reponse:

OUI, le niçveau 1 detecte des caracteres malveillent et lance une alert .

(Q2) Est-il possible d'écrire le code malicieux directement dans le formulaire ?

reponse:

cela depend du niveau au quelle notre cite multidilae est-t-il configuré, deplus pour ecrire un code malicieux tout d'abord on doit ecrire un code java script qui contient le code malveillent.

(Q3) En observant le code de la page dns-lookup.php, repérer les sécurités activées à ce niveau.

```php
<?php
    /*...*/

    try {
        switch ($_SESSION["security-level"]){
            default: // Default case: This code is insecure
            case "0": // This code is insecure. No input validation is performed.
                $lEnableJavaScriptValidation = false;
                $lEnableHTMLControls = false;
                $lProtectAgainstMethodTampering = false;
                $lProtectAgainstCommandInjection=false;
                $lProtectAgainstXSS = false;
            break;

            case "1": // This code is insecure. No input validation is performed.
                $lEnableJavaScriptValidation = true;
                $lEnableHTMLControls = true;
                $lProtectAgainstMethodTampering = false;
                $lProtectAgainstCommandInjection=false;
                $lProtectAgainstXSS = false;
            break;
```

reponse:

Au niveau "1", seules les validations côté client (JavaScript et contrôles HTML) sont activées, tandis que les protections serveur contre l'injection de commande, l'XSS et la manipulation de méthode restent désactivées.

(Q4) Quels sont les caractères typiques utilisés lors d'une attaque XSS ?

reponse:

Les caractères essentiels d'une attaque XSS sont `< > " ' /`, car ils permettent de forger des balises HTML (comme `<script>`) ou de manipuler des attributs JavaScript.

Deplus on utilise également `( ) ; =` pour exécuter des fonctions et structurer le code injecté.

(Q5) Est-ce que le niveau de sécurité 5 permet d'éviter l'attaque avec BurpSuite ?

reponse:

OUI, Le niveau 5 bloque l'attaque via le navigateur

(Q6) En observant le fichier dns-lookup.php, repérer les variables spécifiques associées à ce niveau de protection.

reponse:

```
        case "5": // This code is fairly secure
            $lProtectAgainstCommandInjection=true;
            $lEnableHTMLControls = true;
            $lEnableJavaScriptValidation = true;
            $lProtectAgainstMethodTampering = true;
            $lProtectAgainstXSS = true;
        break;
    }// end switch
```

(Q7) Expliquer le rôle de l'instruction suivante dans le fichier dns-lookup.php (ligne n° 44) :

7. Expliquer le rôle de l'instruction suivante dans le fichier `dns-lookup.php` (ligne n° 44) :

```
$lProtectAgainstMethodTampering?$lTargetHost = $_POST["target_host"]:$lTargetHost = $_REQUEST["target_host"];
```

reponse:

Cette ligne utilise un opérateur ternaire pour restreindre la source des données : si la protection est active, elle force l'usage de $_POST (plus sûr) ; sinon, elle accepte $_REQUEST (permissif), autorisant ainsi l'envoi de paramètres via l'URL ou les cookies.

(Q8) Que vérifie la protection contre les injections de commandes ?

reponse:

La protection contre les injections de commandes vérifie que la saisie correspond strictement au format attendu d'une **adresse IPv4, IPv6 ou d'un nom de domaine valide** via des expressions régulières (Regex).

Elle empêche ainsi l'utilisation de caractères de chaînage (comme `;`, `&&` ou `|`) qui permettraient d'exécuter des commandes système arbitraires sur le serveur.

(Q9) Quelle fonction permet d'éviter spécifiquement les attaques de type XSS ?

reponse:

La fonction qui permet d'éviter les attaques XSS dans ce code est `$Encoder→encodeForHTML()`.

Elle convertit les caractères spéciaux (comme `<` ou `>`) en entités HTML, empêchant ainsi le navigateur de les interpréter comme du code exécutable.

(Q10)Modifier le code source de la page dns-lookup.php afin d'isoler l'effet de cette protection.

reponse:

modification:

```
$lEnableJavaScriptValidation = true;
$lEnableHTMLControls = true;
$lProtectAgainstMethodTampering = false;
$lProtectAgainstCommandInjection = false;
$lProtectAgainstXSS = true; // Changez 'false' par 'true' ici
break;
```

Dans cette modification même si le niveau est configuré sur "1", le serveur appliquera désormais la fonction `$Encoder→encodeForHTML()` sur la saisie. Les balises comme <script> seront affichées sous forme de texte brut à l'écran au lieu d'être exécutées par le navigateur.

(Q11) Résumer les protections mises en œuvre par le niveau de protection n°5.

reponse:

Le niveau 5 assure une sécurité maximale en activant la validation serveur par Regex (contre les injections de commandes), l'encodage des caractères (contre le XSS) et la restriction stricte à la méthode POST (contre la manipulation de paramètres), tout en maintenant les contrôles JavaScript et HTML côté client.

----------Défi N°2----------

(Q1) dzdq

reponse: